BreakBite · PRM393 Final Assignment Report

One complete system on Firebase (Spark plan) · Group 2 · 13 November 2026
Source code: https://github.com/baonv0817/PRM393_Lab03_Group2 · Web admin: https://breakbite-1315b.web.app · Demo video and demo accounts for each role: README.md.

> **How to read this report.** Every claim that a part "works" points to a file in the repository: a test, a screenshot in `evidence/` or a document in `docs/`. The web screenshots and all measurements were taken on the deployed system and the real Firebase project `breakbite-1315b`. What is not done is listed in section 13 and is not written as if it were finished. Labels of the apps are quoted in Vietnamese, with their meaning in brackets.

1. Changes since Lab 3

Lab 3 was a Flutter Android app (folder `lib/`) for customers and kiosk staff, with its data on Firestore, plus FCM, Analytics, Crashlytics, Remote Config and file storage on Cloudinary. The final assignment joins the Lab 2 design and the Lab 3 app into **one system**: an Android app, a web admin and one shared Firebase backend.

Change	What changed	Where
Repository split	Into `packages/core` (shared package), `mobile/`, `web/` and `firebase/`. Models and repositories moved into the shared package so the web reuses them.	commit `5cd0019`; docs/architecture.md
Web admin	W01–W05 for staff and admins, plus 8 system pages for admins; deployed on Firebase Hosting.	#105, #108–#113
Notification inbox	The S19 inbox combines order status messages and the announcements an admin publishes, updated live.	#106
AI feature	Gemini pre-fills the dish details in K14 from a photo of the dish (level 2 of the handout).	#96; docs/ai-feature.md
Roles and rules	Three roles; only an admin changes a role; each app turns away accounts with the wrong role. The rules tests grew from 88 to 172.	firebase/firestore.rules
App Check	Android uses the debug provider (debug builds) or Play Integrity; the web uses reCAPTCHA Enterprise. Enforced for Firestore and AI Logic.	#128; docs/firebase-design.md section 8
Gap review closed	Every Lab 2 and Lab 3 requirement checked again; the bugs found were fixed and the missing evidence added.	docs/gap-review.md

2. Gap review: the scope of Lab 2 and Lab 3

The team went through every flow, screen and requirement of Lab 2 and Lab 3 again and logged each gap as a G item (to fix) or a V item (to verify). The full table, with evidence for each screen: docs/gap-review.md. Result: **16 of 21 items closed**; the 5 open items are listed in section 13.

Item	Problem	Status
G01	S15 showed "Không tải được số đơn" (could not load the order count)	Closed: gone once the current rules were deployed
G02	A receipt could be exported for a cancelled order that was never paid	Closed: button hidden and export blocked (#119)

G03	"Outside opening hours" follows the phone clock	Open, see section 13
G04, G05, G06	The card of an active order could not be tapped; the label "Mã nhận tại…" was easy to mistake for the pickup code; text was cut off at 200 % font size; status labels contradicted each other	Closed (#125, #126)
G07	The "Âm báo đơn mới" (new order sound) switch in K10 was not built	Closed: reason recorded in D21 (Android already lets users mute the "Đơn mới" notification channel)
G08	Figma not updated with the changes to the design	Open, see section 13
G09, G10	The architecture document and a few other lines still described the Lab 3 structure	Closed (#122)
G11	README missing the names and student IDs of the team	Open: the team fills it in
G12	The AI events had no DebugView screenshot	Closed (#124)
V01, V02	Flows F6, F8 and F9 not yet run on a device	Closed: ARTEMIS TC-30 and TC-32 to TC-34, 3/3 each (#127)
V03	The offline screen S30 and a wrong code at K05 had no screenshot from a device	Closed: evidence/gap/ (#127)
V04	Lab 2 flows F4, F5 and F7 not recorded in the repository	Closed: F4 to F13 in docs/design-traceability.md section 3
V05, V06	The phone side of the cross-role flow; enforcing App Check	Closed (#128)
V07	Cloudinary instead of Cloud Storage in the final assignment	Open: the lecturer agreed for Lab 3; to be confirmed again for the final assignment
V08	No secrets in the git history	Closed (#123)
V09	The commits of every member visible on GitHub	Open: to check before the deadline

3. Architecture

Both apps follow MVVM with Provider and go_router. Screens only draw the state and pass user actions to their ViewModel; the ViewModel holds the state (loading, empty, error, data) and calls repositories and services through interfaces; only the implementations of the repositories and services call Firebase or Cloudinary.

Folder	Role
`packages/core`	Models, business rules, the repository interfaces and their Firestore implementations, the shared Firebase services, the role check of each app, the Lab 2 theme and widgets.
`mobile/`	The Android app: screens S01–S30 for customers and K01–K15 for staff; the services that need Android plugins (FCM, Crashlytics, AI Logic, image picker, PDF).
`web/`	The web admin: screens, ViewModels and the wiring of dependencies. No models or repositories of its own.
`firebase/`	Security Rules, indexes, rules tests, the Remote Config template, the Hosting configuration, seed and migration scripts.

Architecture tests run with `flutter test` in both apps: screens and ViewModels may not import the Firebase SDK, ViewModels only use `package:flutter/foundation.dart`, the shared package imports

neither app, and the web has no `lib/data` or `lib/domain` folder. Evidence: mobile/test/architecture_test.dart, web/test/architecture_test.dart; full description in docs/architecture.md.

REST API. Dish photos, incident photos and PDF receipts are uploaded to Cloudinary through its REST API (HTTP POST, unsigned upload preset), with their metadata in Firestore. Cloud Storage is not used because it needs the Blaze plan; the lecturer agreed to Cloudinary or S3 (README, section "Deviations from the handout").

4. Data model and Security Rules

The data has 12 collections: `users` (with `notifications` and `favorites`), `kiosks` (with `slots`), `menu_items`, `vouchers`, `carts`, `orders`, `reviews`, `incidents`, `reports`, `announcements` and `audit_logs`. Each field, who may create, read, update and delete it, and which screens use it: docs/data-model.md.

Who may do what (checked by tests)

Collection	Customer	Kiosk staff	Admin	Tests
users	Read and edit own profile; cannot change own role	Edit own name; cannot read customer profiles	Change the role of other users	R-01 – R-06
notifications	Only the owner of an inbox reads and writes it; nobody reads another user's inbox			R-07 – R-12
kiosks, slots	Read kiosks; book a slot (+1)	Open and close own kiosk; create slots at own kiosk	Create kiosks, change capacity	R-13 – R-24
menu_items	Read; cannot change prices	Edit and archive the items of own kiosk	Create items at any kiosk	R-25 – R-31
vouchers	Read	Read; cannot switch a voucher off	Create, edit	R-32 – R-37
carts	Only the owner of a cart reads and writes it			R-38 – R-43
orders	Create a pending order; cannot approve it	Approve, or reject with a reason, only at own kiosk	Read the orders of every kiosk	R-44 – R-52
reviews	Review an order they collected	Read	Read	R-53 – R-58
incidents	Report and read own incidents	Handle the incidents of own kiosk	Reject with a note	R-59 – R-64
reports	The owner of a file saves and reads its metadata; nobody edits it			R-65 – R-70
announcements	Read published ones	Read published ones; cannot publish	Write, publish, archive	R-71 – R-80

Nobody may delete business data (users, kiosks, slots, menu_items, vouchers, orders, reviews, incidents, announcements): items and announcements are archived instead. The `audit_logs` are read by admins only and written together with each change.

Order lifecycle

From	To	Who may change it
`pending`	`preparing`	Staff of that kiosk, with an estimated ready time
`pending`	`cancelled`	The customer cancels, or kiosk staff reject it with a reason
`preparing`	`ready`	Kiosk staff mark the food as ready

`ready`	`delivered`	Kiosk staff scan or type the pickup code

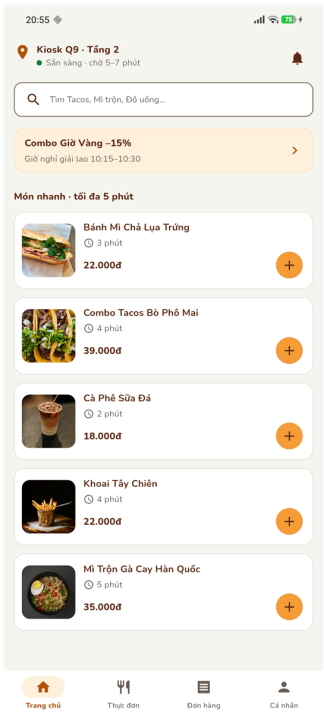
Principles of the rules

- The last rule denies everything: `match /{document=**} { allow read, write: if false; }`. There is no `if true`.
- The shape of the data is checked on create and update (`validNewOrder`, `validMenuItem`, `validAnnouncement`…), each change of status is checked (`validTransition`), and times are server times.
- The role comes from `users/{uid}.role`. Only an admin changes a role, and nobody changes their own (R-02, R-05). Staff only edit the orders and items of their own kiosk (R-27, R-28, R-50).

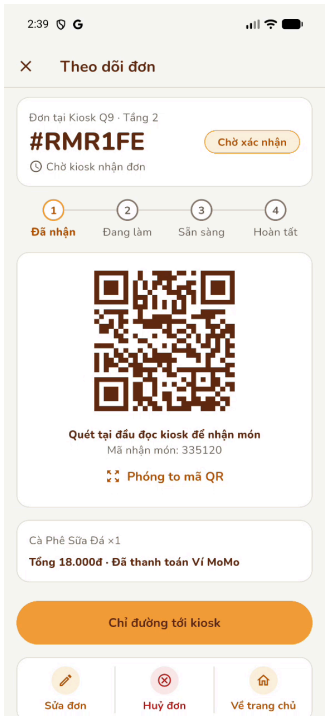
Result: **172/172 rules tests pass** on the Firebase Emulator, including the matrix of 80 allowed and denied pairs for each role on each collection. Evidence: firebase/tests/rules.test.mjs, evidence/rules/rules-run-2026-11-13.log; the matrix is in docs/test-report.md section 1. The deployed rules are the tested rules.

5. Android app

The app runs every Lab 2 flow on real data: quick order (F1), voucher (F2), payment error then cash (F3), editing and cancelling an order (F4), history (F5), favourites and reorder (F6), account (F7), notifications and pickup (F8), closed kiosk and sold-out item (F9), plus the selling flow of the staff. The table that maps each flow to its screens and test cases: docs/design-traceability.md section 3. The app turns away admin accounts and points them to the web admin.



Home



Order tracking



Notification inbox



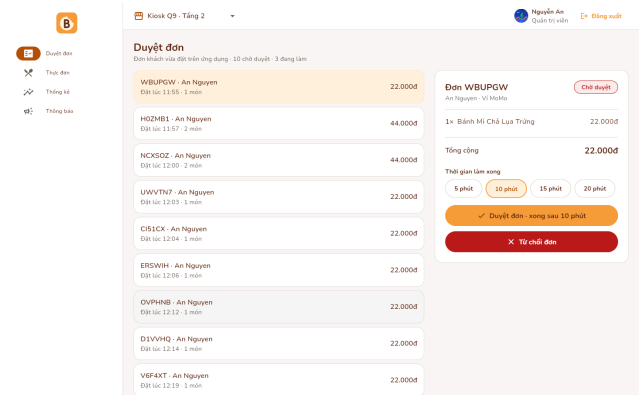
New orders at the kios

6. Web admin

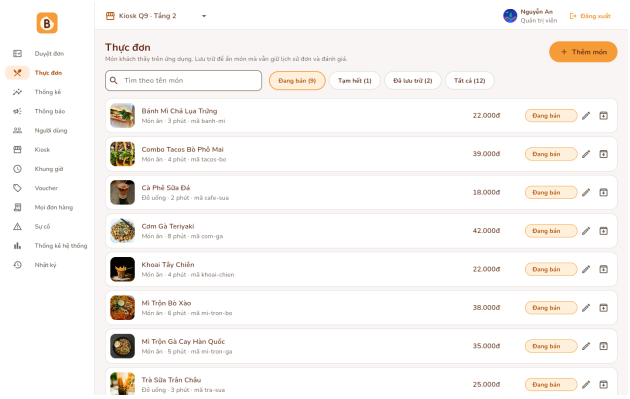
The web admin is written in Flutter Web, reuses the Lab 2 theme and widgets from the shared package with a layout for wide screens, and runs at https://breakbite-1315b.web.app. Each screen was checked on the deployed site against four points: the main action, turning away the wrong role, the empty state and the error state when offline. A screenshot for each cell: evidence/web/; checklist:

docs/test-report.md section 2.

Screen	Main action	Wrong role turned away
W01 Sign-in	Google or email	A customer account is signed out with a message
W02 Menu	Filter, add, edit, mark sold out and archive items	Staff only edit the items of their own kiosk
W03 Review queue	Approve with a preparation time, or reject with a reason (the reasons come from Remote Config)	Staff of another kiosk cannot approve
W04 Statistics	Aggregation queries (count, sum, average); today and the last 7 days	Staff only read the orders of their own kiosk
W05 Announcements	Write, publish and archive announcements	Only admins can write



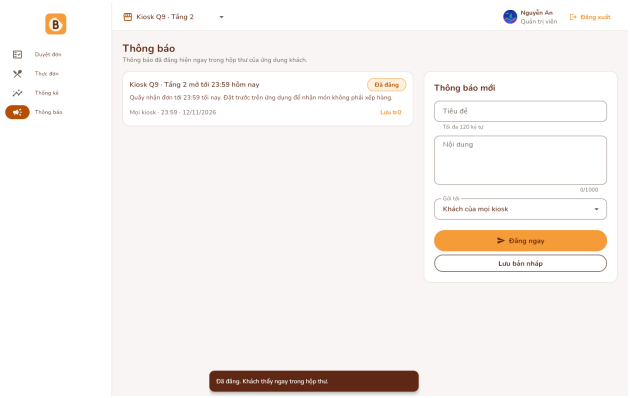
W03 Review queue



W02 Menu



W04 Statistics



W05 Published announcements

Bugs found while checking, and fixed: offline, W02 said "Kiosk chưa có món" (the kiosk has no items yet) because Firestore returned an empty cache (#110); an admin who switched kiosk with the review queue open still saw the queue of the old kiosk (#111); Hosting served the old build for an hour because of a cache header (#112).

7. Cross-role flow

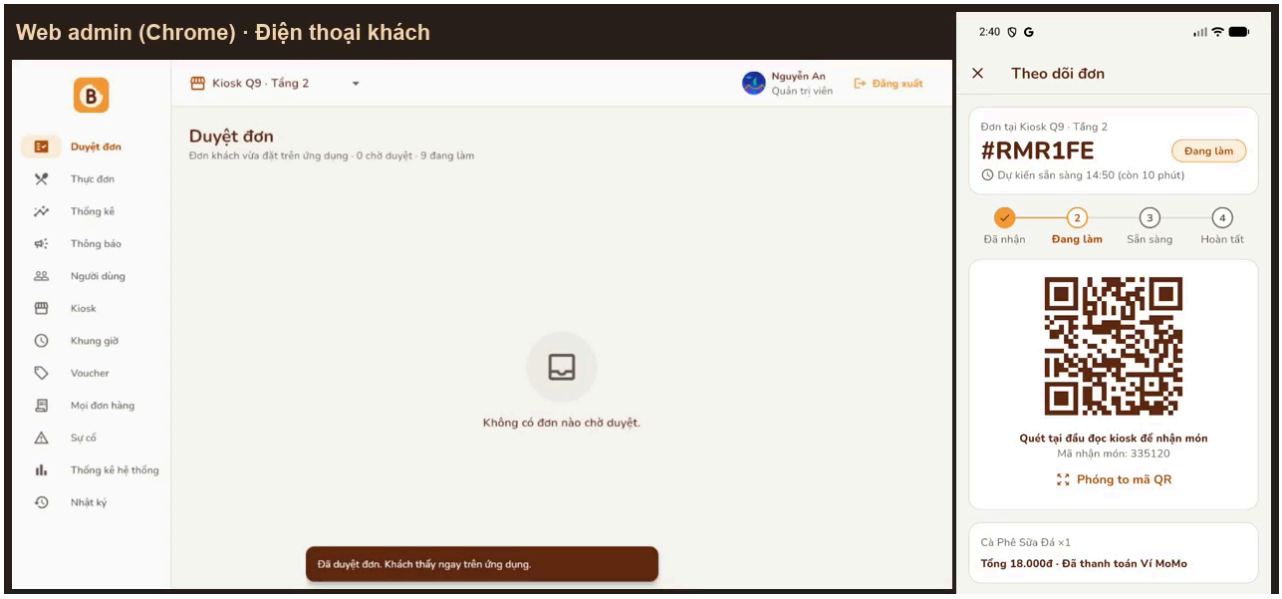
Flow 1, order: the customer places an order on the phone (pending) → it appears at once in W03 of the kiosk → staff approve it with a preparation time, or reject it with a reason → the customer's order tracking screen changes by itself, without a reload, and the inbox gets a new message. **Flow 2, announcement:** an admin publishes in W05 → the customer's inbox shows it at the top; archiving it removes it. Sequence diagram, related rules and how the times were measured: docs/cross-role-

flow.md.

The times were measured on the deployed system: the phone was recorded with `screenrecord --bugreport` (the phone clock is printed on each frame), the time of the click on the web came from the browser, and the offset between the two clocks was measured separately.

Run	On the web	The phone shows	Time
1 · order #QLOTIR	Approve, 10 minutes	Preparing · estimated ready time	1.22 s
2 · order #25RPEH	Reject: "Quầy sắp đóng cửa" (the kiosk is closing soon)	Cancelled · with the reason	1.09 s
3 · order #S7SWIR	Approve, 15 minutes	Preparing · estimated ready time	1.14 s
Flow 2	Publish an announcement	Top of the inbox	1.13 s
Flow 2	Archive the announcement	Gone from the inbox	0.81 s

Evidence: evidence/cross-role/measurements.json; the videos and the before and after screenshots are in evidence/cross-role/. The phone side of flow 1 is also covered by ARTEMIS TC-42 (approve) and TC-43 (reject), 3/3 each. The second run found that a rejected cash order still promised a refund; fixed (#114).



Frame of the demo video: the web has just approved order RMR1FE and the customer's phone has switched to "Đang làm" (preparing).

8. AI feature

In K14, staff choose or take a photo of a dish and tap "Điền bằng AI" (fill with AI). The photo goes to Gemini (`gemini-3.5-flash-lite`) through Firebase AI Logic, and the answer comes back in a fixed JSON schema with the name, category, price, preparation time and description. Design, prompt and decisions: docs/ai-feature.md.

Level 2 requirement	How	Evidence
Remote Config	`ai_enabled` switches it on and off, `ai_model` picks the model, `ai_prompt` is the prompt	firebase/remote-config-defaults.json; demo video

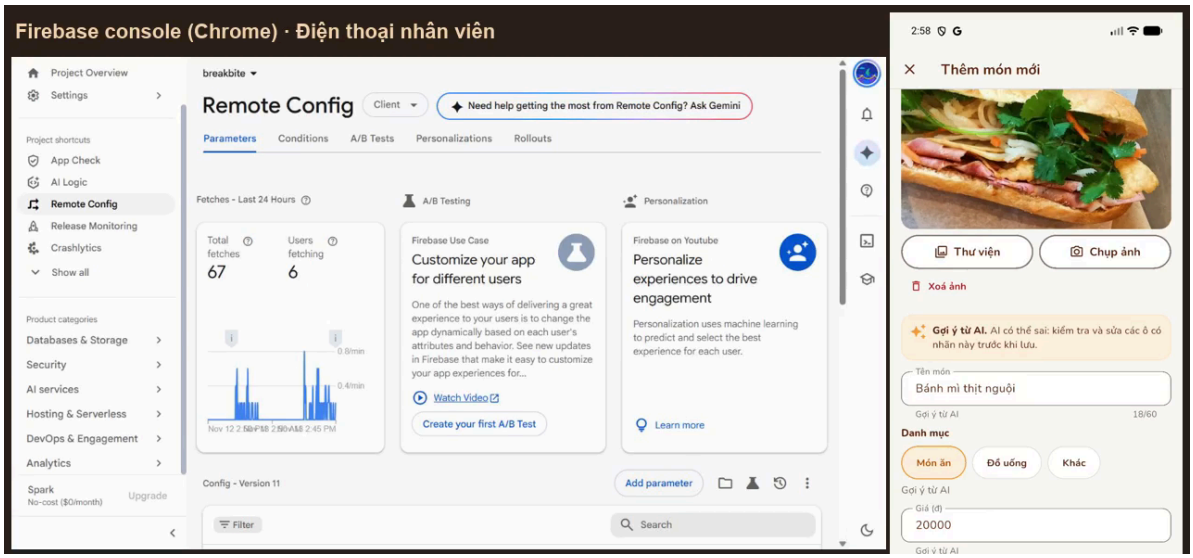
App Check	Enforced for AI Logic (and for Firestore)	App Check console screenshot
Fallback	Quota exceeded, no network, a photo that is not food, a malformed answer: the reason is shown and the form can still be filled in by hand	K14 AI tests; ARTEMIS TC-41
No personal data	Only the photo of the dish is sent; the prompt tells the model not to describe people in the photo	docs/ai-feature.md
Labelled and editable	Each field filled by the AI is labelled "Gợi ý từ AI" (AI suggestion); staff edit it before saving; a field typed by hand is never overwritten (CR-F01)	evidence/ai/
Analytics events	`ai_request`, `ai_result_accepted`, `ai_error`	DebugView



The AI fills every field from a photo of a bánh mì



A photo that is not food



Frame of the demo video: Remote Config has published `ai_enabled = false`, and the add item screen on the phone no longer has the "Điền bằng AI" button.

ARTEMIS TC-40 (photo of a dish) and TC-41 (photo that is not food) both pass 3/3.

9. Testing

Type	Result	Evidence
Security Rules (Emulator)	**172/172 pass**	evidence/rules/rules-run-2026-11-13.log
Web admin W01–W05	All 4 points for each screen, with screenshots	docs/test-report.md section 2
ARTEMIS (Google), Android device	19 scenarios, 3/3 each	docs/test-plan.md section 3; `evidence/artemis/run-*.xml`
Cross-role flow on the real system	3 runs, 1.09–1.22 s; flow 2: 1.13 s	docs/cross-role-flow.md
Unit and widget tests	821 (mobile) and 84 (web) pass	`flutter test` in `mobile/` and `web/`

ARTEMIS

Flow	Test	Runs	Pass
F1 quick order (with the `purchase` event in Logcat)	TC-03	runs 12 to 14	3/3
F2 voucher and voucher errors	TC-04	runs 31 to 33	3/3
F3 payment error, then cash	TC-05	runs 22 to 24	3/3
F6 favourites, quick reorder	TC-32, TC-33	runs 61 to 63; runs 50 to 52	3/3; 3/3
F8 food ready → inbox → pickup code	TC-34	runs 50 to 52	3/3
F9 sold out → alternative dish	TC-30	runs 53 to 55	3/3
Selling flow, from accepting an order to handing it over	TC-12	runs 37 to 39	3/3
Sign-in, sign-out, search, tabs, detail screens, file export, Remote Config	TC-01, 02, 06–10	runs 1 to 8, 34 to 36	3/3 each
AI: photo of a dish, photo that is not food	TC-40, TC-41	runs 43, 44, 46; runs 43 to 45	3/3; 3/3
Cross-role, phone side: approve, reject	TC-42, TC-43	runs 47 to 49	3/3; 3/3

The new ARTEMIS tests (TC-30, TC-32 to TC-34, TC-42, TC-43) prepare and clean up their own data, and they check the result against Firestore instead of trusting the agent's report. This caught two runs where the agent reported "added to cart" while the cart was still empty. Runs that failed because the emulator was overloaded, or because the ARTEMIS model returned a 503 error or ran out of quota, were run again; the cause of each is in docs/test-plan.md sections 3.3 to 3.6.

10. AI code review

Claude Code `/code-review` (medium level) was run on the new code of the final assignment: the web admin, the inbox, the role checks in the shared package, and the AI feature. Raw output: evidence/code-review/final/review-2026-11-13.md. The team checked every finding against the code; all 10 were real.

ID	Type	Finding	Decision

CR-F01	Bug	The AI result overwrote a field staff had just typed; "Save" could be tapped while the AI was running	Fixed (#116)
CR-F02	Bug	A failed publish or archive in W05 showed no error; the button could be clicked twice	Fixed (#117)
CR-F03	Security	The background push handler wrote to Firestore without App Check	Fixed (#118)
CR-F04	Bug	Admins saw "Chưa có kiosk nào" (no kiosks yet) while the list of kiosks was loading; query errors were swallowed	Fixed (#117)
CR-F05	Security	A release build given a debug token would use the App Check debug provider	Fixed (#118)
CR-F06	Bug	The photo was uploaded before the duplicate-name check, which left unused images on Cloudinary	Fixed (#116)
CR-F07	Performance	"Đọc hết" (mark all as read) saved the notifications one by one	Fixed (#118)
CR-F08	Limitation	The 50 newest announcements are fetched before filtering by kiosk	Not fixed: there are only a few announcements a week, and a correct fix needs two queries. Recorded as a known limitation
CR-F09	Maintenance	The length limits of K14 were declared in two places	Fixed (#116)
CR-F10	Maintenance	The account labels were written twice, once in the web app and once in the mobile app	Fixed (#117)

11. Security

- **Permissions on the server:** every permission is in the Security Rules (section 4); the apps only hide what a role may not do.
- **App Check is enforced** for Firestore and AI Logic. Android uses the debug provider (debug builds only, CR-F05) with a token registered in the console; the web uses reCAPTCHA Enterprise. Before enforcing it, the metrics of the last 7 days showed 80% of the requests verified, and the rest came from old builds of the app. After enforcing it, the phone still loaded Home and wrote the cart, and the web read Firestore 9 times out of 9. docs/firebase-design.md section 8.
- **No secrets in the repository:** a scan of the whole git history (298 commits) found no API keys, service account keys, tokens or passwords. What is committed on purpose (the Firebase API key, the unsigned Cloudinary upload preset, the reCAPTCHA site key) is explained in evidence/security/secret-scan-2026-11-13.md.
- **Keys and passwords outside the repository:** the App Check debug token in `mobile/env/app_check.json` (gitignored), the model keys of ARTEMIS in the `.env` of the ARTEMIS server, and the passwords of the demo accounts, sent to the lecturer privately.

12. Lessons learned

- **Some bugs only show up on the real system.** The three bugs in sections 6 and 7 (the empty

cache when offline, the review queue that did not follow the kiosk, the wrong refund promise) all passed the tests that use fake data.

- **Automated tests must check the real data.** The ARTEMIS agent sometimes reported a step as done when it was not. Reading Firestore again after each test is what showed whether a result was real.
- **Look at the metrics before enforcing App Check.** 20% of the requests were unverified, and they came from old builds of the app. The team checked the tokens of both apps before enforcing it, then checked again afterwards: the phone still loaded and wrote data, and the web read Firestore 9 times out of 9.
- **The free plan limits the design too.** Without Cloud Functions, the order status messages are written by the app while it is open, and reminding a customer to collect the food after 10 minutes is not possible yet.
- **Split out the shared package early.** The models and repositories were already separate in Lab 3, so splitting the repository for the final assignment only meant moving folders. The web reuses the repositories and the rules, so one fix applies to both apps.
- **The test environment affects the results.** An overloaded emulator made the app report "not responding", and one restart from an old snapshot brought back an old build of the app. Problems of the environment have to be separated from bugs of the app before drawing a conclusion.

13. Limitations and open items

Limitation	Impact	Way forward
Android not registered with Play Integrity	With App Check enforced, only debug builds with a registered debug token can read data	Register a debug token for the grader's device; publish the app on Google Play to use Play Integrity
No server (Spark plan)	No reminder when a customer forgets to collect the food; status messages are only written while the app is open	Cloud Functions after moving to the Blaze plan
Opening hours follow the phone clock (G03)	A phone with the wrong time may show the kiosk as open or closed by mistake	Check against the server time when an order is placed
CR-F08	If one kiosk has more than 50 announcements, older announcements of other kiosks may be filtered out	Two queries, merged on the client
Figma not updated (G08)	The changes to the design (D01–D39) are only recorded in the documents	docs/design-traceability.md section 5
The persona is a proto-persona	No interviews with real users yet; the goal of 35 seconds and 8 taps has not been measured with users	Interview real users and time them

14. AI tools used

Tool	Used for
Claude Code (Claude Opus 5.5, Claude Sonnet 5.5)	Writing and fixing code, tests and documents; running and measuring the cross-role flow; code review (`/code-review`); building the slides, the report and the demo video. The team checked every result before adding it to the repository.

Google ARTEMIS with Gemini 3.5 Flash Lite	The UI test agent on an Android device (e2e_test/README.md)
Gemini 3.5 Flash Lite through Firebase AI Logic	The AI feature in the app (K14)
Microsoft Edge TTS (vi-VN-HoaiMyNeural)	The narration of the demo video